

Identity Risk Investigation & Response Report

Microsoft Entra ID Protection • Conditional Access • Incident Deep-Dive

TENANT	TENANT ID	REPORT DATE	ANALYST ROLE
Zava	0527ecb7-06fb-4769-b324-fd4a3bb865eb	23 Jun 2026	Tier 2 SOC
zava-corp.com		08:50 UTC	Identity Risk Mgmt

Scope: tenant-wide identity-risk posture, top risky users, full deep-dive on the highest-risk active account, Conditional Access gap analysis with simulated impact, and a prioritised (advisory) response plan. Data source: Microsoft Graph `identityProtection`, `identity/conditionalAccess`, `security/alerts_v2`, `roleManagement` and `users` endpoints, queried live.

1. Executive summary

Bottom line

An active account-takeover of a privileged IT helpdesk identity (**Angel Brown**) is in progress. The account was admin-confirmed compromised on **19 Jun**, yet attacker activity (anonymised/Tor sign-ins, token replay and MFA-approval bombing) **continued through 22 Jun** — meaning containment was started but never completed. Separately, the controls that would have automatically stopped this attack (risk-based Conditional Access) are deployed but left in **report-only** mode.

2,700

Users at-risk or confirmed-compromised (tenant-wide)

1,105

High-risk users

100+

Risk detections in last 30 days

1

Active privileged compromise (this report)

- Trend:** identity risk is **increasing**. The dominant recent detection types are *anonymised IP (Tor/VPN) sign-ins* (43), *unfamiliar sign-in properties* (21), *AI compound account risk* (13) and *suspicious MFA-app approvals* (12) — a profile consistent with adversary-in-the-middle (AiTM) phishing and MFA-fatigue campaigns rather than simple password guessing.
- Top risk driver:** phishing-resistant MFA is **not enforced** for privileged users; push-approval MFA is being actively defeated.
- Biggest quick win:** move the existing risk-based Conditional Access policies from *report-only* to *enforced*, and require phishing-resistant MFA for all admin/helpdesk roles.

2. Identity risk posture

Current Entra ID Protection state across the tenant (live counts):

Metric	Value	Notes
Users in <code>atRisk</code> or <code>confirmedCompromised</code>	2,700	Large standing backlog — remediation is not keeping pace with detection.
High-risk users	1,105 (41%)	Disproportionately high share at the top severity.
Recent detections (30 d, sampled top 100)	100	State split: 49 remediated, 25 still at-risk, 23 dismissed, 3 confirmed-compromised.

Risk breakdown by category (last 30 days, top 100 detections)

Detection type	Count	What it indicates
Anonymised IP address (Tor/VPN)	43	Attacker obscuring origin; multi-hop proxy (T1090.003).
Unfamiliar sign-in features	21	Sign-ins inconsistent with the user's normal pattern.
AI compound account risk	13	Correlated multi-signal risk escalation by Entra ML.
Suspicious MFA-app approval	12	MFA-fatigue / push-bombing (T1621).
Anomalous token	5	Token replay / AiTM session-cookie theft.
Unlikely travel	2	Geographically impossible sign-in pairs.
Risky IP address	1	Sign-in from a known-malicious IP.

Risk level split of those detections: 63 medium • 28 low • 9 high.

3. Top 5 highest-risk users

#	User	UPN	Risk	State	Last updated	Why risky / recommended action
1	Angel Brown Helpdesk Administrator, IT	angelb@vnevado.alpineskihouse.co	High	Confirmed	19 Jun 2026	55 detections in 5 days from Tor/anonymised IPs across 8+ countries, token replay and MFA-approval bombing; activity continued post-confirmation. Action: full containment (see \$5) — not yet complete.
2	Tivadar Karu	u2054@int.zava-corp.com	High	Confirmed	21 May 2026	Admin-confirmed compromised; verify session revocation and password reset were completed and risk closed.

3	Joni Sherman	jonis@vnevado.alpineskihouse.co	High	Confirmed	18 May 2026	Confirmed compromised and already targeted by a dedicated CA block policy ("InsiderRisk High Block All App - Jonis"). Confirm block is still effective; close out risk state.
4	Ardak Thy	u794@int.zava-corp.com	High	Confirmed	18 May 2026	Admin-confirmed compromised; validate remediation and monitor for re-compromise from the same infrastructure.
5	Lina Eriksson	u421@int.zava-corp.com	High	Confirmed	11 May 2026	Admin-confirmed compromised; confirm credentials rotated and tokens revoked.

Common pattern across these accounts: anonymised-IP access, MFA-approval abuse and token anomalies — i.e. session/identity theft, not brute force. The single active, highest-evidence case (Angel Brown) is investigated in full below.

4. Deep-dive investigation — Angel Brown

Account context

Display name	Angel Brown
UPN	angelb@vnevado.alpineskihouse.co
Job title / dept	Helpdesk Administrator / Information Technology
Object ID	9d984ee8-d2bf-4c38-8543-02e80a14c4d3
Account enabled	Disabled (disabled after detection)
Created	17 Mar 2025
Last successful sign-in	22 Jun 2026 15:44 UTC
Group membership	IT Helpdesk Team; All Users; DemoUsers
Active Entra admin role	None at review (account disabled)

Authentication methods (the weakness)

Method	Detail
Password	Registered 14 Jun 2026 (4 days before confirmation)
Microsoft Authenticator	"iPhone 15" — push approval, software token

No phishing-resistant method

The account has only password + Authenticator *push*. There is no FIDO2 key, passkey or certificate. Push-approval MFA is exactly the factor defeated by the observed MFA-fatigue (**T1621**) and AiTM token theft. A privileged helpdesk identity should be phishing-resistant only.

Sign-in & risk timeline (selected events, 18–22 Jun 2026)

Time (UTC)	Detection	Risk	Source IP	Geo	Interpretation
18 Jun 08:43	anonymizedIPAddress	med	198.96.155.3	Kitchener / CA	First anonymised-IP access
18 Jun 08:44	anonymizedIPAddress ×6	med	2001:67c:... / 2a0b: / 2a0d:	NL / DE / SE	Burst across 4 countries in <30 s — impossible travel
19 Jun 06:11	riskyIPAddress	med	198.96.155.3	—	Known-bad IP
19 Jun 06:11	adminConfirmedUserCompromised	conf	—	—	Analyst confirmed compromise
21 Jun 12:23	anomalousToken + anonymizedIP	med	77.48.28.239	Dobransy / CZ	Token replay — 2 days after confirmation
21 Jun 12:24	anonymizedIPAddress ×9	med	107.189.29.8	Luxembourg / LU	Tor exit node burst
22 Jun 10:03	anomalousToken + anonymizedIP	high	194.15.115.212	Singapore / SG	High-risk token anomaly

22 Jun 15:25–15:44	suspiciousAuthAppApproval ×6	low	37.228.201.85 / 104.214.184.226 / 192.166.246.83	IE / HK / SG	MFA-approval bombing — last activity, 3 days post-confirmation
--------------------	------------------------------	-----	--	--------------	---

Full set: 55 detections (43 anonymised-IP, 8 suspicious MFA approvals, 2 anomalous tokens, 1 risky IP, 1 admin-confirmation). User-agent across events: `Edg/149` / `Chrome/149` on varied Windows builds — consistent with a phishing/AiTM toolkit relaying the session.

Is this account compromise? — Assessment: **Yes (confirmed, still active)**

Evidence supporting compromise:

1. **Geographic impossibility:** successful access from Canada, Netherlands, Germany, Sweden, Czechia, Luxembourg, Singapore, Ireland and Hong Kong within hours/seconds — not physically possible for one user.
2. **Anonymisation:** 43 of 55 detections originate from Tor/VPN exit nodes (`T1090.003`) — legitimate users rarely do this; attackers routinely do.
3. **Token anomalies:** `anomalousToken` events indicate replay of a stolen session token, the signature of AiTM session-cookie theft that bypasses MFA.
4. **MFA-approval abuse:** repeated `suspiciousAuthAppApproval` (`T1621`) shows the attacker pushing approvals to wear the user down.
5. **Admin confirmation:** already set to `confirmedCompromised` on 19 Jun.

Critical containment gap

Successful sign-ins and new risk detections occurred on 21 and 22 Jun — **2–3 days after** the account was confirmed compromised. This proves the attacker's **session tokens were never revoked** and the account was not promptly disabled. Confirming compromise without revoking sessions does not evict the attacker.

Most likely attack scenario

Adversary-in-the-Middle (AiTM) phishing → **session-token theft** → **MFA-fatigue persistence**, targeting a privileged helpdesk identity:

1. **Initial access** (`T1566` / `T1078`): user phished via an AiTM proxy that captured credentials and the post-MFA session cookie.
2. **Defence evasion** (`T1090.003`): attacker replays the session from Tor/anonymised IPs to blend in and hide origin.
3. **Credential access / MFA bypass** (`T1621`, **anomalous token**): stolen token replayed; when re-auth needed, push-approval bombing is used to coerce approval.
4. **Persistence:** a fresh password method was registered 14 Jun; activity continued post-confirmation because tokens stayed valid.
5. **Objective:** a Helpdesk Administrator can reset other users' passwords/MFA — ideal for lateral movement and privilege expansion across the tenant.

5. Recommended response plan (advisory — no actions taken)

Ordered for fastest attacker eviction with least business disruption:

#	Action	Why / order rationale	User impact	Risk reduction	Automate?
1	Revoke all sign-in sessions / refresh tokens for Angel Brown	Evicts the live attacker immediately; the missing step so far. Do this <i>first</i> — disabling alone doesn't kill existing tokens instantly.	Account already disabled; none additional	Very high	Auto
2	Keep account disabled & confirm	Stops new interactive auth while investigating.	User cannot sign in (already the case)	High	Auto
3	Force password reset + re-register MFA	Invalidates stolen credential and the attacker-registered password method.	User re-enrols on return	High	Human approve
4	Remove/quarantine MFA methods ; require FIDO2/passkey re-enrolment	Eliminates push-bombing vector; closes the root weakness.	User provisioned a security key	High	Human approve
5	Audit helpdesk-admin actions 14–23 Jun (password resets, MFA changes on other users)	Detects lateral movement the attacker may have performed with helpdesk rights.	None	Med–High	Human
6	Block/monitor observed IPs & hunt other users from same infrastructure	Finds co-victims (Tor set, 194.15.115.212, 77.48.28.239, 107.189.29.8).	None	Med	Auto (hunt)
7	Close risk state once verified clean	Keeps ID Protection signal accurate.	None	Low	Human

Safe to fully automate

Session/token revocation, account disable, IP-based hunting, and risk-signal collection are reversible, low-blast-radius and time-critical — ideal for an automation rule / Logic App playbook triggered on `confirmedCompromised`.

Require human approval

Password reset, MFA method removal, role changes and final risk-dismissal affect user access and should keep an analyst in the loop — particularly for privileged identities.

6. Conditional Access gap analysis

The tenant has **55 CA policies** (significant sprawl, including many duplicate/merged and report-only entries). The most important finding: **the controls that would have stopped this exact attack exist but are not enforced.**

Policy	State	Gap / impact
Require multifactor authentication for risky sign-ins (signInRisk high/med)	Report-only	Would have challenged the medium/high-risk Tor sign-ins. Not enforced.
Block high risk users from sensitive apps	Report-only	Would have blocked the high-risk user from admin portals/O365. Not enforced.

Require password change for high-risk users	Report-only	Would have forced credential rotation automatically. Not enforced.
Require password change on Risky Sign-in	Report-only	Same as above for sign-in risk. Not enforced.
Baseline: phishing-resistant MFA for admins	Report-only	Would have forced FIDO2/passkey for the helpdesk admin — directly blocks AiTM/push-bombing. Not enforced.
Block device code flow	Report-only	Device-code is a common AiTM/token-theft path. Not enforced.
MFA for admin roles	Enabled	No grant control captured (<code>builtInControls</code> empty) — verify it actually enforces an auth strength; otherwise a no-op.
CA01 - MFA For All / MFA for all	Enabled	Enforces MFA but permits <i>push</i> approval — insufficient against this threat; upgrade to phishing-resistant strength.
Block Legacy Auth	Enabled	Good — keep.

Simulated impact on Angel Brown

Replaying this incident against an **enforced** policy set:

- **Require MFA for risky sign-ins (enforced):** the 18 Jun medium-risk Tor burst triggers an MFA challenge; with a phishing-resistant factor the replayed token cannot satisfy it → **access blocked at first anonymised sign-in.**
- **Block high-risk users from sensitive apps (enforced):** once risk hit high (22 Jun), admin portals/O365 are blocked → **no privileged action possible.**
- **Require password change for high-risk users (enforced):** forces rotation automatically, invalidating the stolen credential without analyst action.
- **Phishing-resistant MFA for admins (enforced):** push-bombing has nothing to bomb → the entire [T1621](#) vector disappears.

Net: the 5-day window would have been a single blocked sign-in.

7. Lateral-movement / attack-path simulation

Plausible attacker path from this compromised helpdesk identity, and the control that breaks each step:

Stage	Attacker action	ATT&CK	Control that breaks the chain
1. Initial access	AiTM phish of Angel Brown; steal session cookie	T1566 / T1078	Phishing-resistant MFA (FIDO2/passkey)
2. Defence evasion	Replay token from Tor/anonymised IPs	T1090.003	Enforced risky-sign-in MFA + token protection
3. Persistence	Register new password/MFA method	T1098	Auth-method change alerting + admin approval
4. Privilege use	Use helpdesk rights to reset other users' passwords/MFA	T1098 / T1556	Block high-risk users from admin portals; PIM just-in-time
5. Lateral movement	Sign in as freshly-reset victims; expand foothold	T1078	Enforced user-risk block + session revocation
6. Impact	Mailbox rules, data access, BEC, further phishing	T1114 / T1537	Session controls, DLP, mailbox-rule alerting

Single most effective break-point: enforce phishing-resistant MFA for all privileged/helpdesk roles. It removes stages 1–3 simultaneously.

8. SOC efficiency / ROI

Estimated analyst effort for this single investigation, manual vs agent-assisted:

Task	Manual	Agent-assisted	Best fit
Pull & correlate risk detections + sign-ins	~30 min	~1 min	Full automation
Build timeline & geo/IP analysis	~25 min	~1 min	Full automation
Account/role/auth-method context	~15 min	<1 min	Full automation
CA gap analysis + simulation	~40 min	~2 min	Augmentation
Compromise judgement & scenario	~20 min	~2 min (analyst validates)	Augmentation
Response decisions (privileged)	~20 min	Analyst-led	Human-in-the-loop
Total	~2.5 hrs	~10 min + review	—

Suitable for **full automation**: evidence collection, timeline building, enrichment, IP hunting, session revocation on confirmed-compromise. Suitable for **augmentation**: judgement, CA design, privileged-account response.

9. Recurring weaknesses & strategic improvements

Recurring weakness (observed)	Strategic improvement
-------------------------------	-----------------------

Risk-based CA policies left in report-only	Promote to enforced; establish a change-gate so security policies don't sit unenforced.
Push-MFA defeated by AiTM / fatigue across multiple users	Tenant-wide phishing-resistant MFA roadmap; mandatory for all privileged roles now.
Confirmed-compromise without session revocation	Automate token revocation + disable on <code>confirmedCompromised</code> .
2,700 standing risky users / 55 CA policies (sprawl)	Risk-remediation SLA & backlog burn-down; consolidate and clean up CA policies.
Privileged helpdesk identities with standing access	Move helpdesk admin to PIM just-in-time with approval.

10. Board-level summary

What happened: an attacker took over the account of an IT helpdesk staff member by tricking them through a fake sign-in page, then stole the “digital pass” that keeps them logged in. Because that pass was never cancelled, the attacker kept getting in for several days, from many countries, hiding behind anonymity networks.

Why it matters: helpdesk staff can reset other employees' passwords, so this one account could be used to unlock many others — a stepping stone to wider compromise, data theft or fraud.

What we found: the safety controls that would have automatically stopped this were already built, but switched to “watch only” instead of “enforce”. The login security in use (phone tap-to-approve) is no longer strong enough against this kind of attack.

What we're doing: cut off the attacker's access to the affected account, turn the existing safety controls on, and upgrade logins for staff with elevated access to phishing-resistant security keys. None of these changes disrupt normal staff.

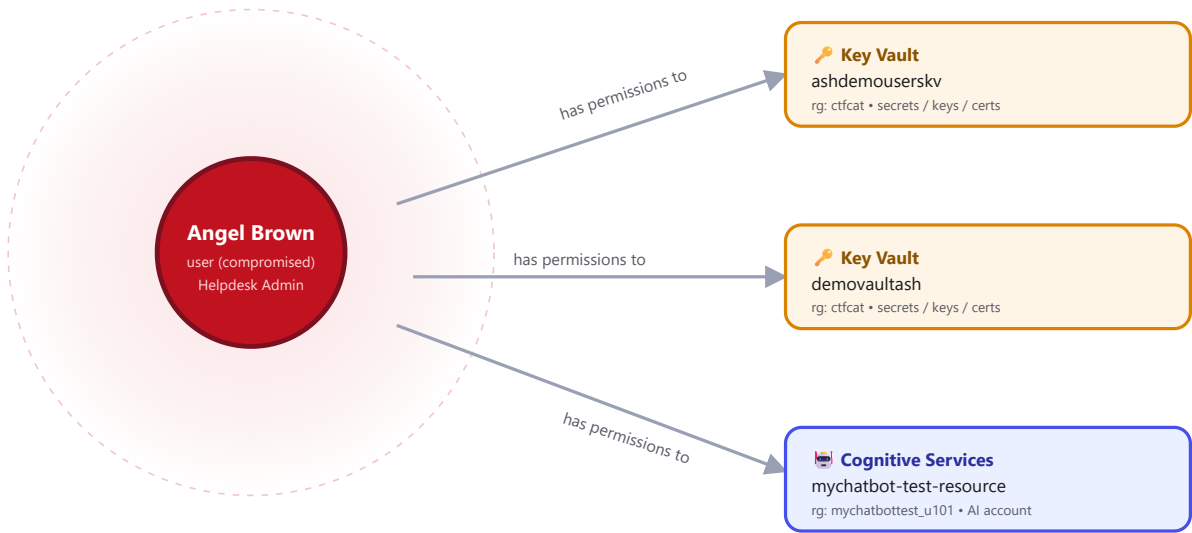
Residual risk: moderate and falling once controls are enforced; the broader backlog of risky accounts needs a funded clean-up programme.

11. Blast radius — Sentinel exposure graph

Computed live from the Microsoft Sentinel / Security Exposure graph for the compromised identity **Angel Brown**. The graph resolves the walkable paths an attacker could traverse from this account, revealing the assets directly reachable if the identity is fully controlled.

Why this matters

Two of the three reachable assets are **Azure Key Vaults** (secret, key and certificate stores). A compromised identity with permissions to a Key Vault can exfiltrate application secrets and certificates, enabling onward access to whatever those secrets protect — a classic credential-access → lateral-movement pivot ([T1552](#) / [T1078](#)).



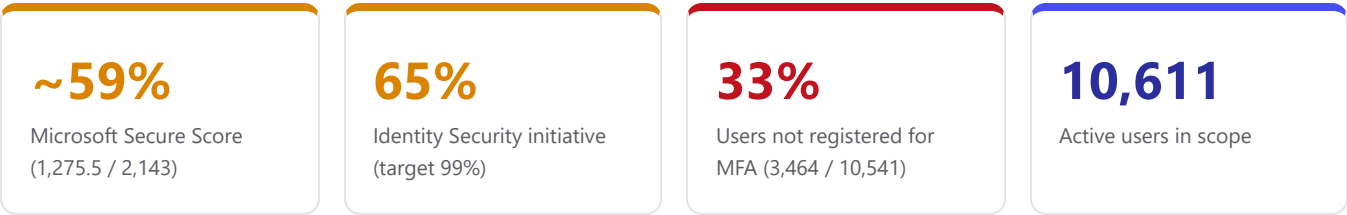
Source: Sentinel exposure graph `find_blastradius`. Edge type: *has permissions to*. 3 directly reachable assets across 2 subscriptions.

#	Reachable asset	Type	Relationship	Subscription / resource group	Impact if reached
1	<code>ashdemouerskv</code>	Key Vault	has permissions to	99005f96... / ctfcats	Theft of secrets, keys, certificates → downstream credential access
2	<code>demovaultash</code>	Key Vault	has permissions to	99005f96... / ctfcats	Theft of secrets, keys, certificates → downstream credential access
3	<code>mychatbot-test-resource</code>	Cognitive Services (AI)	has permissions to	4fc2c46b... / mychatbottest_u101	Abuse of AI service, key theft, data access

Graph criticality on these specific demo assets is rated *None* with no known vulnerabilities, so the immediate blast radius is contained to 3 assets in 2 subscriptions. The principal concern is the **two Key Vaults**: containing the identity (session revocation per \$5) before secrets are pulled is time-critical. Recommended follow-up: rotate any secrets/keys in `ashdemouerskv` and `demovaultash` accessed during 18–22 Jun, and review the account's Key Vault access policies / RBAC for least-privilege.

12. Identity security posture (tenant-wide)

Live snapshot from Microsoft Secure Score (/security/secureScores , 23 Jun 2026), which underpins the Exposure Management “Identity Security” initiative. This provides the strategic backdrop to the individual compromise investigated above.



Biggest weaknesses (highest-value gaps)

Control	Current state	Why it matters
Phishing-resistant MFA for admins	To address	Direct root cause of the Angel Brown compromise (\$4).
Admin MFA (AdminMFAV2)	2 of 17 admins not MFA-protected	Privileged accounts exposed.
MFA registration	3,464 of 10,541 users (33%) unregistered	Large unprotected population.
Entra ID Protection — sign-in risk policy	Planned (off)	Would auto-block risky sign-ins.
Entra ID Protection — user risk policy	To address	Would auto-remediate risky users.
Block legacy authentication	Not fully implemented	Legacy auth bypasses MFA.
Password expiry policy	Set to never expire	Stale-credential risk.
Self-service password reset	2,192 of 10,655 users without SSPR	Slows safe recovery.

On-premises / hybrid (Defender for Identity)

- Unsafe permissions on **Entra Connect** and AD (DNS Admins, AdminSDHolder, replication permissions); multiple **ADCS** misconfigurations; leaked-credential and dormant privileged-account findings.
- Sensor coverage gaps — **ADFS 0/1**, Entra Connect **2/3**, ADCS 1/1 — blind spots on identity infrastructure.
- 2 global admins (healthy), but a very large number of accounts hold least-privileged admin roles — warrants a least-privilege review.

Link to the incident

The posture explains the takeover precisely: the two controls that would have prevented it — **phishing-resistant MFA for admins** and the **Entra ID Protection risk policies** — are not enforced (planned / to-address), matching the report-only Conditional Access gaps in §6. With a third of users lacking MFA and risk policies off, the tenant is broadly exposed to the same AiTM / MFA-fatigue technique.

Top 3 posture priorities (fastest risk reduction)

- Enforce** the Entra ID Protection sign-in-risk and user-risk policies (flip from planned / report-only to on).
- Require phishing-resistant MFA** for all admin/helpdesk roles now; drive the 33% MFA-registration gap down.

3. **Block legacy auth** tenant-wide and remediate the Entra Connect / ADCS unsafe-permission findings.

Appendix — methodology & data sources

- Live Microsoft Graph queries (read-only): `/identityProtection/riskyUsers` , `/identityProtection/riskDetections` , `/identity/conditionalAccess/policies` , `/security/alerts_v2` , `/users` , `/users/{id}/authentication/methods` , `/users/{id}/memberOf` , `/roleManagement/directory/*` .
- Blast radius (§11): Microsoft Sentinel / Security Exposure graph `find_blastradius` (walkable-paths analysis).
- Identity posture (§12): Microsoft Secure Score `/security/secureScores` (latest snapshot, 23 Jun 2026).
- Tenant: Zava (`zava-corp.com`), tenant ID `0527ecb7-06fb-4769-b324-fd4a3bb865eb` . Investigator context: `u1242@int.zava-corp.com` .
- Time window: risk posture as-of 23 Jun 2026; deep-dive 18–22 Jun 2026.
- **No changes were made to the tenant.** All remediation in §5 is advisory.
- ATT&CK techniques referenced: T1566, T1078, T1090.003, T1621, T1098, T1556, T1114, T1537, T1552.

Generated by GitHub Copilot acting as a Tier 2 SOC analyst on 23 Jun 2026. Confidential — handle per data-classification policy.